

INFORMATION SECURITY

RISK SUMMARY REPORT

ResolvX - GRC Compliance & Audit Readiness Programme
Phase 2: Risk & Controls | Version 1.1 | July 2026

Classification	Owner	Methodology	Review Cycle
Confidential	GRC Lead	NIST 800-30 + FAIR	Quarterly

Executive Summary

ResolvX has completed its inaugural formal information security risk assessment as part of Phase 2 of the GRC Compliance & Audit Readiness Programme. This report presents findings to organisational leadership, providing a clear view of ResolvX's current risk posture, the financial exposure associated with top risks, and the remediation priorities required to achieve target compliance certifications and protect client trust.

25 risks were identified and assessed across five categories: Cyber Threat, Cloud & Infrastructure, Vendor & Third-Party, Compliance & Regulatory, and Human & Operational. The assessment applied the NIST SP 800-30 Rev. 1 methodology for qualitative scoring and the FAIR model for financial quantification of high and critical risks.

Update - July 2026

Since the baseline assessment, ResolvX has delivered a 26-document policy suite (POL-007 through POL-026) plus supporting evidence artifacts (Security Monitoring Report, DR Failover Tabletop Test Report, Policy Exception Register), closing or substantially treating 19 of the 25 risks in this report. This is a full revision. See §7 Document Control for the complete history.

Key Findings at a Glance

Metric	Finding
Total risks assessed	25 across 5 categories
Critical risks (residual)	0 - unchanged
High risks (residual)	0 - down from 8 at baseline
Moderate risks (residual)	7 - down from 11
Low risks (residual)	8 - up from 5
Very Low risks (residual)	10 - up from 0
Risks fully mitigated	10 of 25
Risks with treatment plans	25 / 25
Overall risk trajectory	Substantially improving

Assessment Note

Figures represent residual risk after accounting for current controls. The elimination of all 8 High residual risks — 3 fully mitigated, 5 reduced to Moderate with named remaining gaps — reflects the formal policy suite closing the gap between controls that existed informally and controls that are documented, owned, and enforced.

1. Risk Posture Overview

1.1 Inherent vs Residual Risk Distribution

The following table shows how ResolvX's current controls shift risk levels from inherent (pre-control) to residual (post-control). Inherent risk is a fixed baseline and does not change; residual risk reflects the current control state.

Risk Level	Score	Inherent	Residual (baseline)	Residual (July 2026)
Critical	20–25	8	0	0
High	12–19	10	8	0
Moderate	7–11	5	11	7
Low	4–6	2	5	8
Very Low	1–3	0	1	10

No risks now sit at High or Critical residual level. The programme's immediate action priority has shifted from “reduce High risks” to “complete SOC 2 certification and close the remaining named tooling gaps” (see §6).

1.2 Risk Distribution by Category

Category	Risks	Highest Level (baseline)	Highest Level (current)	Primary Remaining Driver
Cyber Threat	5	High	Moderate	Ransomware DR site, pentest cadence, SBOM/codesigning
Cloud & Infrastructure	5	High	Moderate	Named CSPM tooling (Security Hub, Access Analyzer)
Vendor & Third-Party	5	Moderate	Moderate	Stripe/PCI scope (deferred by design)
Compliance & Regulatory	5	High	Low	SOC 2 external audit engagement pending
Human & Operational	5	Moderate	Low	Quarterly phishing simulation cadence

2. Top Moderate Residual Risks

Previously “Top 8 High Residual Risks”. High or Critical risk are now 0. This risks below are retained for continuity and audit trail. Each entry shows what closed and what remains.

RSK-001 - Ransomware Attack

Field	Baseline	Current (July 2026)
Residual Score	12 (High)	8 (Moderate)
Delivered	-	Immutable Critical-tier backup copy (POL-009 §6.4); CloudTrail S3 MFA-delete (POL-007 §6); ransomware tabletop already exercised (IR-TTX-001)
Remaining	Vault lock; immutable backups; tabletop	AWS Backup vault lock; active-passive DR site
Status	Open	In Progress

RSK-003 - API Vulnerability Exploitation

Field	Baseline	Current (July 2026)
Residual Score	10 (Moderate)	8 (Moderate)
Delivered	-	30-day High-severity SLA, continuous Snyk scanning, automatic ticketing (POL-010)
Remaining	Weekly scanning; SLA; pentest	Named annual pentest cadence; AWS Shield Advanced
Status	In Progress	In Progress

RSK-005 - Software Supply Chain Attack

Field	Baseline	Current (July 2026)
Residual Score	12 (High)	8 (Moderate)
Delivered	-	SCA/SAST/container scanning in CI/CD (POL-018); production dependency standards (POL-011 §6)
Remaining	SBOM; code signing; SAST/SCA	SBOM generation; code signing
Status	Open	In Progress

RSK-006 - AWS S3 Misconfiguration

Field	Baseline	Current (July 2026)
Residual Score	10 (Moderate)	8 (Moderate)
Delivered	-	CIS AWS Foundations Benchmark baseline; public S3 disabled by default (POL-022 §6)
Remaining	Security Hub; IaC guardrails; CSPM review	Named Security Hub deployment; S3 Object Lock
Status	In Progress	In Progress

RSK-008 - IAM Over-Privilege

Field	Baseline	Current (July 2026)
Residual Score	12 (High)	8 (Moderate)
Delivered	-	IAM least-privilege baseline (POL-022 §6); high-blast-radius IAM changes gated (POL-013 §3)
Remaining	Access review; Access Analyzer; SCPs	Named IAM Access Analyzer, SCPs
Status	Open	In Progress

RSK-016 - SOC 2 Type II Certification Failure

Field	Baseline	Current (July 2026)
Residual Score	8 (Moderate)	6 (Low)
Delivered	-	The full 26-policy suite this risk's own treatment action called for, plus evidence artifacts
Remaining	Execute roadmap; engage auditor; policy suite	Engage external auditor is the remaining gate
Status	In Progress	In Progress

RSK-017 - GDPR Violation

Field	Baseline	Current (July 2026)
Residual Score	8 (Moderate)	3 (Very Low)
Delivered	-	ROPA/DSR process (POL-006); formal breach risk methodology and US/EU notification framework (POL-016)
Remaining	Data mapping; DSR process; ROPA	-
Status	Open	Mitigated

RSK-004 (Insider Threat) also moved out of this tier from Moderate (8) to Low (6) on the strength of the DLP Policy (POL-019) and existing quarterly access reviews. Full detail is in the risk register.

3. FAIR Quantitative Risk Analysis

FAIR analysis was originally applied to all risks scoring 12 or above. As of July 2026, no risk meets that threshold, the table below is retained for continued financial visibility on ResolvX's highest-exposure items, not because these risks still qualify under the original rule. ALE dollar ranges are unchanged from baseline pending a full re-quantification; only likelihood inputs have improved.

3.1 Annualised Loss Expectancy (ALE) Summary

Risk ID	Risk	Level (baseline)	Level (current)	ALE Mid
RSK-001	Ransomware attack	High	Moderate	\$775,000
RSK-002	Phishing / credential theft	Moderate	Low	\$257,500
RSK-003	API vulnerability exploitation	High	Moderate	\$615,000
RSK-004	Insider threat / exfiltration	High	Low	\$375,000
RSK-005	Supply chain attack	High	Moderate	\$500,000
RSK-006	AWS S3 misconfiguration	High	Moderate	\$465,000
RSK-008	IAM over-privilege	High	Moderate	\$325,000
RSK-012	Stripe integration breach	Moderate	Moderate (deferred)	\$550,000
RSK-016	SOC 2 certification failure	High	Low	\$1,000,000
RSK-017	GDPR violation	High	Very Low (Mitigated)	\$1,100,000

Total quantified exposure (unchanged dollar estimates): \$2.3M – \$9.6M annualised. Note: ALE figures are probabilistic estimates, not predictions as they inform investment priority, not precise forecasting.

4. Risk Treatment Progress

4.1 Treatment Timeline

Status	Risks	Focus Area
Delivered 2026-07-31	RSK-009, 010, 013, 014, 017, 022, 023, 024, 025	Secrets, logging/monitoring, break-glass, TPRM, GDPR, offboarding, documentation, change mgmt, BCP/DR
In Progress — named gap remains	RSK-001, 002, 003, 004, 005, 006, 007, 008, 016, 021	Policy foundation complete; specific tooling/cadence items remain
Deferred by design	RSK-012, RSK-018	PCI-DSS scope — held for Step 3 material
Not yet addressed	RSK-015, RSK-019, RSK-020	Email authentication, CCPA intake, SLA/commercial risk — outside security policy scope

5. Risk Programme Observations

What Is Working

The foundational security controls already in place, Okta SSO with MFA, AWS GuardDuty, EDR, GitHub branch protection, multi-AZ architecture, and Jamf MDM, have now been joined by a complete, cross-referenced 26-document policy suite covering every domain from logging and monitoring through HR security and exception governance. No risks remain at Critical or High residual level.

Where the Programme Must Focus

- Detection & Response : Largely formalised, not yet fully deployed. POL-007 defines the logging/monitoring programme and a staged SIEM roadmap; Stage 2 (cross-source correlation) is the remaining technical work.
- Cloud Posture Discipline: Governed, tooling still to be named. POL-022 and POL-013 set the hardening baseline and change-gating discipline; RSK-006/008 remain Moderate specifically because named tooling (Security Hub, Access Analyzer) isn't deployed yet.
- Compliance Programme Execution: Down to one external action. RSK-016's treatment action ("execute the GRC roadmap") is substantively complete; the remaining gate is engaging and completing the SOC 2 Type II audit itself.

Risk Appetite Alignment

ResolvX's stated risk appetite (Low for cybersecurity, Very Low for compliance) is now comfortably met at the aggregate level. The remaining 7 Moderate risks all have named owners and specific, dated remaining gaps rather than vague "in progress" status.

6. Recommended Board-Level Actions

Updated July 2026-07-31; two of three original actions are substantially complete; a fourth has taken their place.

1. Approve budget for named tooling (Security Hub, IAM Access Analyzer, SIEM Stage 2): Policy foundation complete; this is now a procurement decision, not a design decision. Est. \$40K–\$80K annually.
2. Formally engage a SOC 2 auditor: Still the top priority, and now the clearest one. This is the single largest remaining gate. Recommended: Drata/Vanta-partnered firms, A-LIGN, Schellman.
3. GDPR data mapping and DSR programme: Complete. POL-006 and POL-016 together move RSK-017 to Very Low. No further board action needed; monitor at next quarterly review.
4. Approve budget for remaining named gaps: SBOM/codesigning, active-passive DR region, quarterly phishing simulation programme. Each is a bounded, budgetable initiative.

7. Document Control

Version	Date	Author	Summary
1.0	2026	Derick G. Dmello, GRC Lead	Initial risk summary report
1.1	July 2026	Derick G. Dmello, GRC Lead	Full revision following delivery of the POL-007–026 policy suite. 19 of 25 risks re-scored; residual High-tier risks reduced from 8 to 0; 10 risks fully Mitigated. See risk_register.xlsx v1.1 for underlying detail.